

SmartFuzz

Security Assessment Report

Target: http://testfire.net/

Scan Date: 2026-05-17 20:54:17 UTC

Scan ID: 3f83ef3d-6ae9-47af-86f2-9e67ab5482a0

1. Executive Summary

Target URL	http://testfire.net/
Scan Date	2026-05-17 20:54:17 UTC
Vuln Classes	SQLi, XSS, RCE, SSRF, Command Injection
Overall Risk	Critical

4	2	0	2	0	1	100
Total	Critical	High	Medium	Low	Forms	Payloads

2. Findings

Summary

#	Vulnerability	Parameter	Severity	Evidence
1	SSRF	content	Critical	—
2	SSRF	content	Critical	—
3	XSS	content	Medium	—
4	XSS	content	Medium	—

Detailed Findings

#1 SSRF — content

Critical

URL	http://testfire.net/index.jsp?content=http%3A%2F%2F169.254.169.254%2Flatest%2Fme
Method	GET
Status	200
Time	—
Payload	http://169.254.169.254/latest/meta-data/
Evidence	—

Fix Whitelist allowed domains. Block requests to internal IP ranges.

#2 SSRF — content

Critical

URL	http://testfire.net/index.jsp?content=http%3A%2F%2F169.254.169.254%2Flatest%2Fus
Method	GET
Status	200
Time	—
Payload	http://169.254.169.254/latest/user-data/
Evidence	—

Fix Whitelist allowed domains. Block requests to internal IP ranges.

#3 XSS — content

Medium

URL	http://testfire.net/index.jsp?content=%27%3Balert%28%27XSS%27%29%2F%2F
Method	GET
Status	200
Time	—
Payload	' ;alert('XSS')//
Evidence	—

Fix Encode all user output. Use Content-Security-Policy headers.

#4 XSS — content

Medium

URL	http://testfire.net/index.jsp?content=%3Cdetails+open+ontoggle%3Dalert%28%27XSS%
Method	GET
Status	200
Time	—
Payload	
Evidence	—
Fix	Encode all user output. Use Content-Security-Policy headers.

3. Remediation Reference

SSRF

Whitelist allowed destination domains. Block requests to 169.254.0.0/16, 10.0.0.0/8, and 192.168.0.0/16. Disable HTTP redirects or re-validate the final destination URL.

XSS

HTML-encode all user-controlled output before rendering. Implement a strict Content-Security-Policy header. Use HttpOnly and Secure flags on session cookies.

4. Disclaimer

This report was generated automatically by SmartFuzz. Results should be reviewed and validated by a qualified security professional before acting upon them. False positives may be present. This tool is intended for use only against systems you own or have explicit written authorisation to test. Unauthorised testing is illegal and unethical.

Generated by SmartFuzz · 2026-05-17 20:54:17 UTC